

# Open Source License Compliance Report

Guidance and gap identification -- not a compliance certification

**DISCLAIMER:** This tool provides regulatory guidance only. Final compliance assessment requires review by qualified legal counsel. Regulatory requirements vary by jurisdiction and product context.

## Product Summary

Product: Example Predictive Maintenance Service

Scan Date: 2026-07-20T16:55:34.157787

Use Case: SaaS

Total Dependencies: 16

Scope note: direct dependencies only; transitive dependencies are not scanned.

## Risk Summary

| Risk Level        | Count | Meaning                                                                          |
|-------------------|-------|----------------------------------------------------------------------------------|
| ■ Safe            | 9     | No restrictions triggered in this context; OK to use as-is.                      |
| ■ Needs Review    | 4     | An obligation may apply; verify before treating as clear.                        |
| ■ Action Required | 3     | An obligation is triggered or the license is unresolved; route to legal counsel. |

## Applicable Regulations

CRA: Cyber Resilience Act (Regulation (EU) 2024/2847)

-> Security-by-design and vulnerability management obligations

-> Components (including open source) must be documented (e.g. SBOM)

-> Vulnerability/incident reporting obligations apply from 11 Sept 2026; essential requirements and conformity assessment apply from 11 Dec 2027. Not a single 'live since 2024' obligation.

NIS2: Network and Information Security Directive 2 (Directive (EU) 2022/2555)

-> Supply chain security requirement

-> Third-party components, including open source, are in scope of the risk assessment

-> A directive, not a regulation -- binding only via each Member State's national transposition law (transposition deadline was 17 Oct 2024). Verify transposition status per jurisdiction.

Data Act: EU Data Act (Regulation (EU) 2023/2854)

-> Data access and portability rights for industrial/machine data

-> General applicability (data access/portability rights) began 12 Sept 2025. The connected-product 'access by design' obligation applies from 12 Sept 2026 -- these are two different deadlines.

AI Act: EU AI Act (Regulation (EU) 2024/1689)

-> Risk-tier classification determines which obligations apply

-> High-risk systems require documentation, logging, human oversight

-> Prohibited practices apply since 2 Feb 2025. High-risk obligations were originally due 2 Aug 2026 (standalone, Annex III) / 2 Aug 2027 (embedded safety components, Annex I), but a May 2026 Digital Omnibus political agreement defers these to 2 Dec 2027 / 2 Aug 2028 respectively -- reconfirm formal adoption status before relying on either date. Penalties are tiered: up to EUR 35M/7% (prohibited practices), EUR 15M/3% (high-risk & most other obligations), EUR 7.5M/1% (misleading information) -- not a flat 6%.

## Detailed Dependency List

| Library  | Version | License            | Risk   | Notes |
|----------|---------|--------------------|--------|-------|
| requests | 2.31.0  | Apache License 2.0 | ■ Safe |       |

|                       |          |                                             |                   |                    |
|-----------------------|----------|---------------------------------------------|-------------------|--------------------|
| flask                 | 2.3.0    | BSD 3-Clause License                        | ■ Safe            |                    |
| psycpg2               | 2.9.9    | GNU Lesser General Public License v3.0 only | ■ Safe            |                    |
| mysqlclient           | 2.2.0    | GNU General Public License v2.0 only        | ■ Needs Review    | Needs legal review |
| pyqt5                 | 5.15.9   | GNU General Public License v3.0 only        | ■ Needs Review    | Needs legal review |
| some-internal-fork    | 0.1      | Unknown                                     | ■ Action Required | Needs legal review |
| express               | ^4.18.0  | MIT License                                 | ■ Safe            |                    |
| lodash                | ~4.17.21 | MIT License                                 | ■ Safe            |                    |
| gpl-sample-lib        | ^1.0.0   | GNU General Public License v3.0 only        | ■ Needs Review    | Needs legal review |
| agpl-sample-lib       | ^2.0.0   | GNU Affero General Public License v3.0 only | ■ Action Required | Needs legal review |
| eslint                | ^8.0.0   | MIT License                                 | ■ Safe            |                    |
| typescript            | ^5.0.0   | Apache License 2.0                          | ■ Safe            |                    |
| vendor-crypto-toolkit | 3.2.1    | Apache License 2.0                          | ■ Safe            |                    |
| vendor-ui-widgets     | 1.0.4    | MIT License                                 | ■ Safe            |                    |
| vendor-report-engine  | 7.1.0    | GNU General Public License v3.0 only        | ■ Needs Review    | Needs legal review |
| vendor-legacy-module  | 0.9.0    | Unknown                                     | ■ Action Required | Needs legal review |

## Actions Required

- some-internal-fork 0.1 (Unknown license): No license could be resolved for this dependency. Its terms are unknown, which means neither permissions nor obligations can be confirmed -- treat as requiring investigation before use.
- agpl-sample-lib ^2.0.0 (GNU Affero General Public License v3.0 only): GNU Affero General Public License v3.0 only requires that source code be offered to any user who interacts with the software over a network -- this is what distinguishes AGPL from GPL, and it applies to SaaS/hosted deployment even without distributing a binary.
- vendor-legacy-module 0.9.0 (Unknown license): No license could be resolved for this dependency. Its terms are unknown, which means neither permissions nor obligations can be confirmed -- treat as requiring investigation before use.

For questions about this report, consult your legal counsel.